Hollin & Wren Ltd: Information Security Standard

Version 2.1. Owner: Head of IT. Approved by the Board on 3 March 2026. Applies to every system that stores or

processes customer, payment or staff information, including systems run for us by suppliers.

1. Purpose

This standard sets the minimum controls for our online shop, our warehouse systems and our back-office tools.

Where a law or the Payment Card Industry Data Security Standard (PCI DSS) asks for more, the stricter rule applies.

2. Data classification

- **Restricted:** payment card data and authentication secrets.
- **Confidential:** customer names, addresses, order history and staff records.
- **Internal:** stock levels, supplier price lists and internal reports.
- **Public:** product pages and marketing content.

Information owners classify their data when a system is designed and review the classification every year.

3. Hosting and data location

Customer and payment data must be stored and processed only in the United Kingdom. Suppliers that host our

data must tell us in writing before moving it to another data centre.

4. Network security

Databases and storage accounts that hold Confidential or Restricted data must not be reachable from the public

internet. Public-facing web applications must sit behind a web application firewall. Remote administration

uses the company VPN and multi-factor authentication.

5. Encryption

All data must be encrypted at rest and in transit using TLS 1.2 or later. Restricted data must be encrypted with

customer-managed keys held in our own key vault, and the keys are rotated at least every two years.

6. Backups and recovery

Backups of production databases must be retained for at least 35 days. Restores are tested every quarter and the

result is recorded in the change log.

7. Logging and monitoring

Security and audit logs must be retained for a minimum of 12 months. Alerts for failed administrator sign-ins go

to the on-call engineer.

8. Cost control

Monthly cloud spend for the ecommerce platform must not exceed £9,000 without approval from the Finance Director.

9. Asset management

Every cloud resource must be tagged with `owner`, `cost-centre` and `data-classification`. Untagged resources are

reported to the Head of IT each month.

10. People

Staff complete security awareness training when they join and every year after that. Passwords are at least 14

characters long and are never shared.